Báo cáo kiểm thử bảo mật

Chế độ: gemini-top10-analysis-extractive

Thời điểm UTC: 2026-10-09T04:08:50.376034+00:00

Số phát hiện đầu vào: 1

Phạm vi khắc phục: OWASP Top 10:2025 - Web Application Security

Phạm vi và giới hạn

- Chỉ đề xuất cho CWE có ánh xạ trực tiếp trong OWASP Top 10:2025 và có bằng chứng đầu vào.

- Gemini chỉ chọn ID đoạn gốc; không tự viết, dịch hoặc bổ sung hướng dẫn khắc phục.

- Trích nguyên văn không chứng minh hướng dẫn phù hợp. Cần người kiểm tra trước khi áp dụng.

- Kho Cheat Sheet Series do người dùng tải từ nguồn chính thức. Hash kiểm tra tính nhất quán với lúc ingest, không xác thực độc lập nguồn tải.

- Nguồn hướng dẫn: OWASP Cheat Sheet Series, CC BY-SA 4.0; https://creativecommons.org/licenses/by-sa/4.0/. Trích đoạn giữ nguyên Markdown gốc.

- Không truy cập source code/database, không chạy quét, tự sửa code hoặc retest.

- Phân tích/tổng quan tiếng Việt do Gemini sinh; ID và trích đoạn đầu vào được kiểm tra, có lượt AI rà soát riêng. Chưa bảo đảm tính đúng ngữ nghĩa.

- AI phân tích không được viết khắc phục. Khắc phục chỉ nằm ở phần trích nguyên văn OWASP có kiểm tra phạm vi.

- Việc cho phép truy xuất khắc phục vẫn dựa trên CWE và bằng chứng không rỗng, không phải đánh giá độ mạnh bằng chứng.

- Dữ liệu gửi Gemini gồm metadata và tối đa 8 đoạn bằng chứng, mỗi đoạn 2400 ký tự; che một số dạng token/mật khẩu phổ biến, không bảo đảm loại hết dữ liệu nhạy cảm. Bằng chứng gốc giữ trong báo cáo cục bộ.

Tổng quan AI

Diễn giải AI đã qua kiểm tra nguồn và một lượt AI rà soát; chưa được xác minh thủ công.

Diễn giải phát hiện: Cong cu kiem thu ghi nhan canh bao SQL Injection duoc gan nhan la ID SQLMAP-0 va thuoc ve CWE-89, voi muc do do kiem thu cung cap la unknown, co 1 muc bang chung va chua duoc xac minh doc lap. [F1]

Diễn giải phát hiện: Tong hop du lieu bao cao ghi nhan tong cong 1 muc canh bao co muc do unknown va co huong dan. [TOTAL]

Thông tin còn thiếu / giới hạn: Canh bao tu cong cu chua duoc xac minh doc lap va thieu thong tin chi tiet de khang dinh kha nang khai thac thuc te. [F1]

Trích đoạn căn cứ đầu vào (đã che một số dữ liệu nhạy cảm):

[F1] ID SQLMAP-0: SQL Injection (sqlmap-reported); CWE CWE-89; mức độ do kiểm thử cung cấp unknown; loại scanner_alert; 1 mục bằng chứng, chưa xác minh độc lập; scope in_scope; có đoạn OWASP: True.

[TOTAL] {"total": 1, "by_input_severity": {"unknown": 1}, "with_guidance": 1}

[F1] 1 mục bằng chứng, chưa xác minh độc lập

SQLMAP-0 - SQL Injection (sqlmap-reported)

Công cụ / nguồn: sqlmap

Loại bản ghi: scanner_alert

Mức độ từ kiểm thử: unknown

Phân loại từ kiểm thử: CWE-89

Vị trí: parameter=q (GET); target URL not established by parser

Tham chiếu đầu vào: input.scan#line=4

Phạm vi OWASP Top 10:2025

Có ánh xạ trực tiếp CWE trong OWASP Top 10:2025; đây không phải xác nhận lỗ hổng thực tế.

Nhóm: A05:2025 Injection

https://top10.owasp.org/2025/A05_2025-Injection/

Phân tích

Kiểm thử cung cấp 1 mục bằng chứng. Giữ nguyên mức độ và phân loại từ đầu vào; chưa xác minh độc lập lỗ hổng. Có ánh xạ trực tiếp CWE trong OWASP Top 10:2025; đây không phải xác nhận lỗ hổng thực tế.

Diễn giải AI

Diễn giải AI đã qua kiểm tra nguồn và một lượt AI rà soát; chưa được xác minh thủ công.

Diễn giải phát hiện: Cảnh báo từ bộ quét ghi nhận phát hiện được gán nhãn SQL Injection (sqlmap-reported) với định danh CWE-89 và mức độ từ đầu vào là unknown. [M1, M2]

Diễn giải phát hiện: Vị trí được ghi nhận tại tham số q thông qua phương thức GET, với bằng chứng kiểm thử bao gồm kiểu boolean-based blind và payload thử nghiệm dạng SYNTHETIC_TEST_VALUE. [M3, E1]

Diễn giải phát hiện: Bản ghi từ đầu vào có một mục bằng chứng, chưa được xác minh độc lập và phạm vi thuộc in_scope. [M4]

Thông tin còn thiếu / giới hạn: Phần phân tích ghi nhận rằng URL mục tiêu chưa được thiết lập bởi bộ phân tích. [M3]

Trích đoạn căn cứ đầu vào (đã che một số dữ liệu nhạy cảm):

[M1] Tên phát hiện do kiểm thử cung cấp: SQL Injection (sqlmap-reported)

[M2] CWE từ đầu vào: CWE-89; mức độ từ đầu vào: unknown; loại bản ghi: scanner_alert

[M3] Vị trí do kiểm thử cung cấp: parameter=q (GET); target URL not established by parser

[E1] Parameter: q (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: q=SYNTHETIC_TEST_VALUE

[M4] Bằng chứng đầu vào: 1 mục. Chưa xác minh độc lập. Phạm vi khắc phục: in_scope.

[M3] target URL not established by parser

Bằng chứng đầu vào

Parameter: q (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: q=SYNTHETIC_TEST_VALUE

Hướng dẫn khắc phục theo OWASP

Hướng dẫn nguyên văn OWASP (tiếng Anh; AI chỉ chọn đoạn)

DO: Using an object relational mapper (ORM) or stored procedures is the most effective way of countering the SQL Injection vulnerability.

Điều kiện áp dụng: Đoạn nguyên văn tiếng Anh do AI chọn; cần đối chiếu với công nghệ và ngữ cảnh thực tế. Không phải bản vá đã kiểm chứng.

Nguồn: DotNet Security Cheat Sheet

https://cheatsheetseries.owasp.org/cheatsheets/DotNet_Security_Cheat_Sheet.html

Mục: DotNet Security Cheat Sheet / .NET General Guidance / A03 Injection / SQL Injection

Nguồn cục bộ: DotNet_Security_Cheat_Sheet.md | ký tự 19917:20054

Đối chiếu nguồn: Chưa duyệt thủ công | S14

Hướng dẫn nguyên văn OWASP (tiếng Anh; AI chỉ chọn đoạn)

DO: Use parameterized queries where a direct SQL query must be used. More Information can be found in the
[Query Parameterization Cheat Sheet](Query_Parameterization_Cheat_Sheet.md).

Điều kiện áp dụng: Đoạn nguyên văn tiếng Anh do AI chọn; cần đối chiếu với công nghệ và ngữ cảnh thực tế. Không phải bản vá đã kiểm chứng.

Nguồn: DotNet Security Cheat Sheet

https://cheatsheetseries.owasp.org/cheatsheets/DotNet_Security_Cheat_Sheet.html

Mục: DotNet Security Cheat Sheet / .NET General Guidance / A03 Injection / SQL Injection

Nguồn cục bộ: DotNet_Security_Cheat_Sheet.md | ký tự 20056:20238

Đối chiếu nguồn: Chưa duyệt thủ công | S15

Dấu vết tái lập

SHA-256 kiểm thử: b4916f5c88cf3b0f2d293568253c02e1e4d93b2fbf10f055a9e6adfdf623e492

SHA-256 kho hướng dẫn: 4920ce4715655ac875baf116bd88e640bb2dc0e9b1a0b150a2bdf82abebe71e2

Model AI: gemini-3.5-flash-lite